

RULES

What to use, what to avoid, and AI boundaries

Project: Internal Knowledge Chatbot — Venus Remedies

1. What to Use

- **Only libraries that are actively maintained** (recent commits, no long-abandoned packages) — check before adding any new dependency
- **Environment variables for all secrets** (API keys, DB credentials) — never hardcoded, never committed to git
- **TypeScript for backend code** if the team is comfortable with it — catches integration bugs (like the wrong-import-name class of bugs) before runtime
- **Structured logging** on the backend (what question was asked, what sources were retrieved, whether the LLM call succeeded) — needed to debug bad answers later
- **A single, consistent way to call the LLM** — one wrapper function (`services/llm.js`), not scattered API calls across the codebase

2. What to Avoid

- **No client-side API keys.** The LLM API key and vector DB service credentials must only ever live in the backend. Never expose them to the frontend, ever — this applies even during quick demos or prototyping.
- **No unverified/hallucinated library APIs.** Every import must be checked against the actual library's documentation before use — do not assume a function/export exists because it "sounds right." (This is a recurring real-world failure mode worth guarding against explicitly.)
- **No silent failures.** If the vector search returns nothing, or the LLM call fails, the user must see a clear message — never a blank response or a generic crash.
- **No answering outside the knowledge base's scope with confidence.** If retrieval returns low-relevance results, the bot should say it doesn't have enough information rather than let the LLM fill the gap from general knowledge. This is core to trust in an internal tool.
- **No storing sensitive personal data** (salary info, medical/HR records, disciplinary records) in the v1 knowledge base — start with genuinely general-purpose docs (IT guides, general policy, FAQs) until access-control per-document is properly designed.
- **No modifying company systems.** This bot only reads and answers — it never writes back to any HR system, ticketing system, or database. Keep the blast radius of a bug limited to "gave a wrong answer," never "changed a record."

3. Boundaries of AI in This Project

- The LLM's job is **strictly to summarize/explain retrieved content** — it is not a general-purpose assistant for this tool. If a question has no matching source document, it should decline rather than answer from its own training knowledge.
- **No autonomous actions.** The AI never sends emails, files tickets, or takes any action on the user's behalf in v1 — it answers questions only.
- **Human review required before expanding scope** into compliance/SOP/audit territory (Idea #1/#2 from the original list) — those carry regulatory stakes that a general knowledge-chatbot pattern isn't built for. Treat this project's success as a foundation, not a green light to expand into higher-stakes domains without a fresh risk review.
- **Every AI-generated answer must be traceable to a source document.** No source, no answer presented as fact.